
DOCUMENTO DE ARQUITECTURA: SEGURIDAD, ACCESO Y VISIBILIDAD

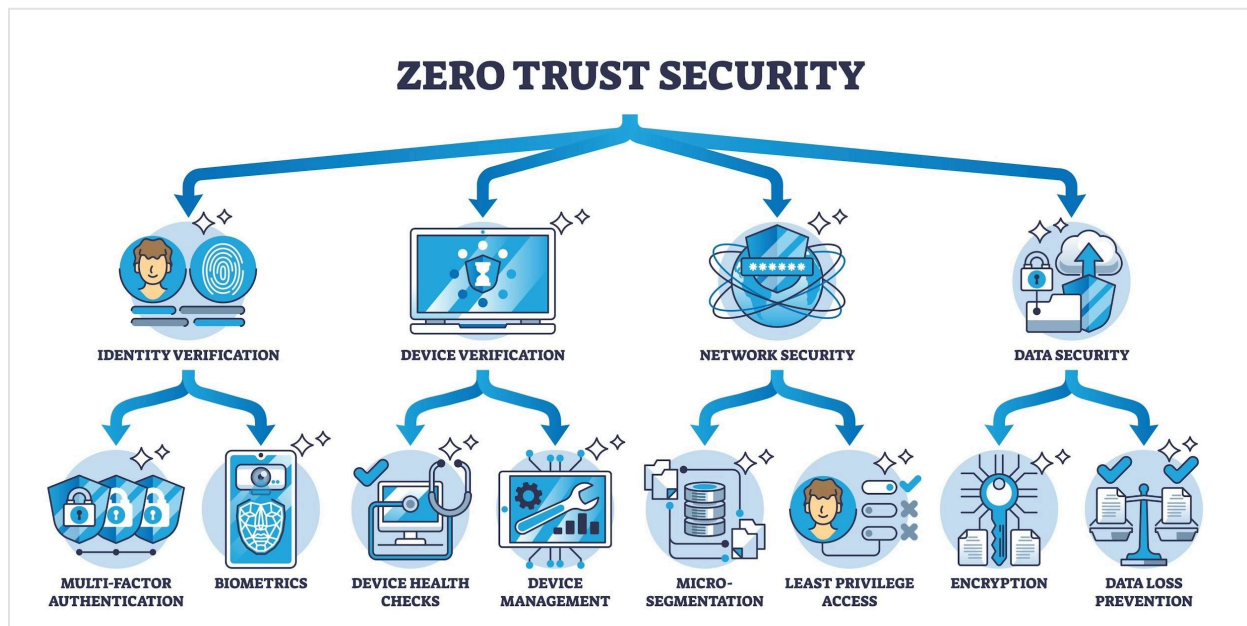
Proyecto: Implementación CRM Banco Macro

Módulo: Salesforce Sharing & Visibility (FSC & Sales Cloud)

Audiencia: Product Owners, Líderes Técnicos, CISO / Seguridad Informática.

1. Introducción y Principios de Diseño

Este documento define la estrategia de control de acceso a los datos dentro de la plataforma Salesforce (Single Org) para el Banco Macro. El modelo se basa en las definiciones de negocio relevadas, donde se prioriza la **Visión 360 colaborativa**, permitiendo la visibilidad transversal de la información, pero restringiendo las acciones de modificación, creación y aprobación mediante una matriz de permisos granular y jerárquica.



Shutterstock

2. Organization-Wide Defaults (OWD)

El OWD es la base de la pirámide de seguridad en Salesforce. Define el nivel de acceso predeterminado que tiene un usuario sobre un registro del cual **no** es propietario.

De acuerdo con las definiciones del negocio, el banco operará bajo un modelo abierto de lectura para evitar duplicados y fomentar el conocimiento global del cliente.

Objeto Salesforce	Nivel OWD Propuesto	Impacto Funcional y Justificación
Account / Contact	Public Read Only	Cualquier usuario puede buscar y ver los datos de un cliente, pero solo el propietario o superiores pueden editarlo. Habilita la Visión 360.
ContactPoint (Address/Phone/Email)	Controlled by Parent	Hereda la seguridad de la Cuenta/Contacto. Si veo la cuenta, veo sus teléfonos.
Lead	Public Read Only	Permite que un oficial vea si un prospecto ya está siendo gestionado por otra sucursal.
Opportunity	Public Read Only	Visibilidad global de los negocios en curso. (Ver Nota de Riesgo abajo).

OpportunityProduct	Controlled by Parent	Los productos cotizados heredan la visibilidad de la Oportunidad.
Campaign	Public Read Only	Visibilidad global de las acciones de marketing para toda la red.
CampaignMember	Controlled by Parent	Hereda la visibilidad de la Campaña y del Contacto/Lead asociado.
Interaction / Activity (Task/Event)	Controlled by Parent	Heredan la visibilidad del registro relacionado (Ej. la Cuenta o la Oportunidad).
FinancialAccount	Public Read Only	Visibilidad global de los productos contratados. (<i>Ver Nota de Riesgo abajo</i>).
FinancialAccountParty	Controlled by Parent	Los titulares/garantes heredan la visibilidad de la Cuenta Financiera.
IssuedCard	Controlled by Parent	El plástico físico emitido es visible si el usuario tiene acceso a la Cuenta Financiera Padre.

FinancialHolding	Controlled by Parent	Las posiciones de inversión heredan la seguridad de la cuenta de inversión (Financial Account).
FinancialSecurity	Public Read Only	Catálogo de instrumentos de inversión (FCI, Acciones). Visible para todos como referencia.
AccountContactRelation	Controlled by Parent	Las relaciones de Socios/Firmantes heredan acceso de la Cuenta y el Contacto.
AccountAccountRelation	Controlled by Parent	Las jerarquías de Grupos Económicos heredan la seguridad de las Cuentas vinculadas.
RecordAlert	Controlled by Parent	Las alertas (Ej. Mora) se visualizan si el usuario tiene acceso a la Cuenta asociada.
Product2	Public Read Only	Catálogo maestro de productos del banco. Visible para todos.
BranchUnit	Public Read Only	Catálogo de sucursales visible para toda la red.

Banker	Public Read Only	Directorio de empleados habilitados para operar.
BranchUnitBusinessMember	Public Read Only	Relación entre banqueros y sucursales, visible para coordinar derivaciones.
BranchUnitRelatedRecord	Controlled by Parent	Hereda la visibilidad del registro derivado a la sucursal.
Actividad__c / Barrio__c / Catalog__c	Public Read Only	Tablas paramétricas (Listados de AFIP, BCRA, zonas geográficas) visibles para categorizar clientes.

Nota de Riesgo Arquitectónico (Secreto Bancario):

Establecer **Opportunity** y **FinancialAccount** como *Public Read Only* significa que cualquier empleado con acceso a Salesforce podrá ver los montos de préstamos, saldos de cuentas y negociaciones de **todos** los clientes del banco. Si el área de Compliance requiere ocultar saldos de clientes VIP o empleados del propio banco, se recomienda cambiar el OWD de estos dos objetos a **Private** (Privado), o bien implementar **Restriction Rules** (Reglas de Restricción) para enmascarar registros altamente confidenciales.

3. Jerarquía de Roles (Role Hierarchy)

Mientras el OWD permite que todos "vean" (Read), la Jerarquía de Roles es el mecanismo que permite a los líderes "gestionar y modificar" (Read/Write/Transfer) los registros de sus equipos.

- **Configuración:** La opción “*Grant Access Using Hierarchies*” estará activada para todos los objetos estándar.
- **Comportamiento Comercial (Oportunidades):** Si un Oficial de Cuentas es propietario de una Oportunidad, su Jefe de Agencia y el Gerente Regional (ubicados arriba en la jerarquía) tendrán acceso total de **Lectura y Escritura**. Esto cumple con el requisito de que un Supervisor pueda intervenir, actualizar, cambiar de etapa o reasignar una Oportunidad de sus liderados sin necesidad de que el sistema se lo comparta explícitamente.

Estructura Propuesta:

1. Directorio / C-Level
2. Gerentes Divisionales (Individuos / Empresas)
3. Gerentes Regionales
4. Gerentes de Sucursal / Supervisores
5. Oficiales / Ejecutivos

4. Reglas de Compartición, Colas y Grupos Públicos

Dado que la organización tiene un OWD público para lectura, las *Sharing Rules* clásicas (que abren visibilidad) se utilizarán exclusivamente para otorgar permisos de **Escritura (Read/Write)** laterales.

4.1. Grupos Públicos (Public Groups)

Se crearán grupos públicos no basados en roles, sino en funciones transversales.

- *Ejemplo:* PG_Mesa_de_Ayuda, PG_Comite_Riesgos, PG_Especialistas_Comex.
- *Uso:* Simplificar la administración al asignar reglas de compartición o acceso a carpetas de reportes.

4.2. Colas (Queues)

Fundamentales para la asignación y balanceo de carga de trabajo, especialmente en escenarios donde el propietario inicial no es una persona.

- **Cola de Leads (Inbound):** Queue_Leads_Digitales almacenará los carritos abandonados hasta que un Oficial de la sucursal correspondiente lo tome (*Accept*).
- **Cola de Casos (Atención):** Queue_Reclamos_Nivel2 para escalar quejas operativas.

4.3. Reglas de Compartición (Sharing Rules)

- **Criteria-Based Sharing Rule:** Si una Oportunidad B2B alcanza la etapa "Análisis de Riesgo", se creará una regla que comparta automáticamente el registro con acceso de *Lectura/Escritura* al grupo público `PG_Comite_Riesgos`.

5. Matriz de Perfiles y Conjuntos de Permisos (Profiles & Permission Sets)

Para evitar la proliferación de Perfiles (anti-patrón de Salesforce), se utilizará el modelo de permisos componibles (Muted Profile + Permission Set Groups).

5.1. Perfiles (Profiles)

- **Perfil Base:** `Macro_Standard_User`. Este perfil tendrá la seguridad mínima indispensable (Login IP, Horarios, Timeouts) y acceso básico a la aplicación, sin permisos de creación o eliminación de objetos críticos (CRUD restringido).

5.2. Permisos Personalizados (Custom Permissions)

Se crearán variables lógicas para satisfacer el requisito de separar a quienes "Crean" de quienes "Aprueban".

- `CustomPermission: Puede_Aprobar_Oportunidad`
- `CustomPermission: Puede_Crear_Cliente_Core`
- *Beneficio:* Estos *Custom Permissions* se evaluarán dentro de Reglas de Validación (Validation Rules), Flujos (Flows) o Procesos de Aprobación. (Ej. *Si el usuario intenta presionar 'Aprobar' y no tiene el CustomPermission, el sistema arroja error*).

5.3. Conjuntos de Permisos (Permission Sets - PS)

Agruparán accesos técnicos granulares y contendrán los *Custom Permissions* mencionados.

- `PS_Oportunidades_Lectura_Escritura`
- `PS_Oportunidades_Aprobacion` (Contiene el *CustomPermission* de aprobación).

5.4. Grupos de Conjuntos de Permisos (Permission Set Groups - PSG)

Es lo que se asignará al usuario final (Persona de Negocio), empaquetando varios PS.

- **PSG: Oficial de Cuentas Individuos:** Contiene permisos para crear Leads, gestionar Cuentas Personales y editar Oportunidades propias.
- **PSG: Gerente de Sucursal:** Contiene permisos del Oficial + Reportes Gerenciales + el `PS_Oportunidades_Aprobacion`.

6. Otros Mecanismos de Visibilidad y Colaboración

Para complementar la arquitectura y soportar el trabajo cruzado (Cross-sell):

- **Account Teams (Equipos de Cuentas):** Se habilitará para que el Propietario de una *Business Account* pueda agregar manualmente a un especialista (Ej. Oficial Plan Sueldo) y otorgarle acceso de *Read/Write* a esa cuenta y sus Oportunidades, fomentando la venta colaborativa.
- **Opportunity Teams (Equipos de Oportunidad):** Similar a Account Teams, pero a nivel de transacción.
- **FSC Compliant Data Sharing:** Si en el futuro surge la necesidad de manejar información confidencial (Ej. Fusiones y Adquisiciones en Banca Corporativa), se utilizará esta capacidad de FSC para blindar el registro más allá del OWD, cumpliendo con la muralla china (Chinese Wall) regulatoria.